



Análisis y Planificación del Pentest.

Aurora Market

Norma Martínez

Septiembre 05, 2026

Aurora Market	Análisis y Planeación Del Pentest	Clave: R-AP-AM-Actividad 1
		Fecha: Septiembre 05, 2026.
		Página 2 de 5

ANTECEDENTES

Considerando la importancia de los servicios de **Aurora Market**, se ha solicitado la ejecución de una evaluación de seguridad de su aplicación web a fin de identificar posibles fallas de seguridad e investigar el posible acceso a información de otra cuenta que fue reportado por un colaborador. El ejercicio de Pentest será preventivo, basado en evidencia, específicamente en:

- Aplicación web.

1. OBJETIVO DEL PENTEST

- Identificar brechas de seguridad que pudieran ser explotadas, evaluar el grado de riesgo y exposición, tomando en cuenta los distintos roles: cliente, personal, administrativo considerando su relevancia para las operaciones.
- Respecto a los accesos, evaluar controles, comprobar autenticación, sesiones, autorización horizontal y vertical y separación de roles, con prioridad en el posible acceso entre cuentas ante lo reportado por un colaborador.
- Documentar evidencia de las pruebas realizadas y de los hallazgos, así como las recomendaciones pertinentes para Aurora Market.

2. ALCANCE

El alcance se enfocará en un ejercicio que contempla el total de las actividades para Pruebas de Penetración tipo caja gris, para el siguiente activo autorizado:

- Aplicación web

Se evaluará la aplicación web autorizada. Interés en: registro, inicio de sesión, productos, carrito, compras, pedidos y funciones internas de administración de productos, usuarios y pedidos; también, autenticación, sesiones, roles, controles de acceso, formularios, solicitudes y respuestas necesarias para valorar su seguridad.

Quedan fuera del alcance de este ejercicio redes sociales, equipos personales, correo, proveedores externos, cualquier activo no autorizado; denegación de servicio y acciones que modifiquen, eliminen o perjudiquen información real.

3. AUTORIZACIÓN Y CONDICIONES

Permisos requeridos. Antes de iniciar *Aurora Market* deberá dar autorización escrita de: plan de trabajo, contacto interno para comunicación, un equipo interno que tenga conectividad al entorno de los diferentes tipos de usuario, aplicación a analizar, no avisar a las áreas internas de negocio o desarrollo para contar con un escenario de operación lo más realista posible, credenciales de prueba.

Condiciones acordadas. Se aceptarán solicitudes o cambios del alcance por parte de *Aurora Market* a través de los correos autorizados con apego a la matriz de comunicación, la matriz de escalación se tomará como base para cualquier eventualidad. No habrá interacción con activos fuera del alcance ni ejecución de pruebas destructivas.

4. TIPO DE PENTEST

El Pentest a ejecutar es **caja gris** gracias a que se tiene conocimiento parcial y credenciales de prueba para roles autorizados, pero no acceso a configuraciones, arquitectura interna, infraestructura o al código fuente. Este modelo permite ejecutar pruebas autenticadas emulando un escenario realista de un usuario legítimo y, a su vez, evaluar la superficie expuesta de manera externa.

Dado que en este enfoque se considera al usuario interno, es necesario tener credenciales de prueba de los distintos tipos de usuarios de la aplicación web.

5. PLANIFICACIÓN

- **Objetivos.** En el Kickoff se validarán y convertirán en criterios de aceptación los objetivos del ejercicio: determinar la exposición de la aplicación web, comprobar autenticación, sesiones, autorización horizontal y vertical y separación de roles, investigar el posible acceso entre cuentas y generar evidencia y recomendaciones. Desde la planeación se mantiene enfoque en la trazabilidad entre requisito, prueba, hallazgo y recomendaciones.
- **Alcance.** La línea base comprenderá exclusivamente la aplicación web autorizada y sus funciones de registro, inicio de sesión, productos, carrito, compras, pedidos y administración de productos, usuarios y pedidos. No se consideran redes sociales, equipos personales, correo, proveedores externos, activos no autorizados y afectación de información real. Se seguirá un Control Integrado de Cambios, por lo que para toda solicitud se evaluarán tiempo, riesgo y entregables, se requerirá aprobación formal antes de modificar la línea base. Riesgos, incidencias y cambios se gestionarán diario con los contactos técnicos, el avance semanalmente.
- **Permisos y condiciones.** Antes del inicio deberán aprobarse por escrito el plan de trabajo, objetivos, cuentas de prueba por rol, contactos, matriz de comunicación y escalamiento, ventanas de ejecución, técnicas permitidas y criterios de suspensión. Las pruebas se detendrán ante degradación, exposición de datos reales, acceso a activos excluidos o instrucción del contacto autorizado; no se realizarán acciones destructivas, persistencia, movimiento lateral ni extracción de información real.
- **Metodología a utilizar.** Se aplicará OWASP WSTG 4.2 bajo enfoque de caja gris, estructurando el trabajo en reconocimiento, análisis, explotación controlada, post-explotación limitada e informes. Cada caso de prueba tendrá objetivo, prerequisites, rol, datos de prueba, evidencia esperada y criterio de detención.
- **Recopilación de información previa.** Se solicitará a Aurora Market la identificación de la aplicación autorizada, cuentas de prueba de los distintos roles, funciones conocidas, mecanismos de autenticación, documentación disponible y antecedentes del reporte del usuario. Esta información interna se complementará con OSINT limitado a la aplicación — dominios relacionados, certificados, tecnologías y contenido público—, sin investigar personas, redes sociales, correo, proveedores ni sistemas excluidos.

- **Recursos.** Se propone un equipo de dos personas: un Líder de Pentest, responsable de alcance, ejecución, escalamiento y reporte, con experiencia en pruebas web y certificación como OSWE, OSCP u otra equivalente; y un Pentester con experiencia en OWASP WSTG, autenticación, sesiones, autorización y lógica de negocio, responsable de ejecución complementaria, validación cruzada y control de calidad; de *Aurora Market* se requiere un responsable autorizador, un contacto técnico y uno operativo para decisiones, acceso y continuidad del servicio.
- **Herramientas.** Nmap, OWASP ZAP, navegador web, fuentes y técnicas OSINT, bitácora y repositorio cifrado de evidencias, cuentas y datos de prueba.
- **Programación del Pentest.** El plan de trabajo consta de 12 días hábiles, la ejecución de pruebas se contempla de la media noche a las 04:00 horas (tiempo de la CDMX), de martes a jueves, como periodo de menor actividad (sujeto a confirmación de *Aurora Market*).

Día	Fase	Actividades
1	Kickoff	Validación de autorización, alcance, exclusiones, cuentas de prueba, contactos, matriz de comunicación y escalamiento, ventanas, técnicas permitidas y criterios de suspensión.
2-3	Reconocimiento	Recopilación interna, OSINT limitado, identificación de tecnologías, puertos, servicios, sesiones y roles.
4-6	Análisis de vulnerabilidades	Pruebas automatizadas y manuales sobre autenticación, autorización, sesiones, entradas, configuración y lógica de negocio.
7-9	Explotación controlada	Validación de hallazgos confirmados mediante cuentas y datos de prueba, con evidencia mínima y detención al demostrar impacto.
10	Post-explotación	Delimitación del alcance técnico, privilegios y recursos afectados, cierre seguro de sesiones y consolidación de evidencias.
11-12	Análisis	Hallazgos y análisis de impacto.
13-14	Informes	Elaboración de reportes técnico y ejecutivo, revisión por pares y QA.

Tabla 1. Plan de trabajo

6. FASES DEL PENTEST

- **Reconocimiento.** Aquí habrá un reconocimiento activo controlado: validación de dominios y subdominios relacionados con la aplicación, certificados, cabeceras HTTP, rutas indexadas, formularios, cookies; flujos de autenticación y comportamiento entre roles; identificación de puertos y servicios permitidos; mapeo de solicitudes, respuestas, identificadores de usuario, pedidos, búsqueda de puntos de entrada para autorización horizontal y vertical, manejo de sesión y posible exposición indebida de información.

Aurora Market	Análisis y Planeación Del Pentest	Clave: R-AP-AM-Actividad 1
		Fecha: Septiembre 05, 2026.
		Página 5 de 5

- **Análisis de vulnerabilidades.** Escaneo de vulnerabilidades en aplicación web; validación de autenticación, recuperación de cuenta, gestión de sesión, autorización horizontal y vertical, validación de entradas, configuración, manejo de errores y lógica de negocio en carrito, compras y pedidos; solicitudes entre cuentas y roles de prueba, identificadores, tokens y parámetros para validar que el servidor aplica restricciones en cada petición.
- **Explotación.** Validación de vulnerabilidades confirmadas a través de pruebas controladas en cuentas de prueba; se reproducirán las condiciones de explotación manipulando al mínimo parámetros, identificadores, tokens, cookies o sesión a fin de demostrar el impacto real sobre autorización, aislamiento entre cuentas, roles, pedidos o funciones administrativas. Al obtener evidencia técnica, la ejecución se detendrá (se excluirá persistencia, movimiento lateral, extracción o modificación de información real).
- **Post-explotación.** El impacto técnico alcanzable desde la vulnerabilidad validada se delimitará, comprobando si el acceso obtenido permite consultar o modificar recursos, escalar privilegios, atravesar límites entre cuentas o roles, reutilizar sesiones o alcanzar funciones administrativas; estas verificaciones se realizarán con cuentas y datos de prueba. Se excluye persistencia, movimiento lateral fuera de la aplicación y extracción de datos reales; se registrarán la cadena de explotación, privilegios alcanzados, recursos afectados y evidencia mínima necesaria, y las sesiones temporales serán cerradas de forma segura.
- **Informe.** Reporte técnico (para corregir y posteriormente con un retest, verificar acciones implementadas) y Ejecutivo (para toma de decisiones estratégicas informadas), que contendrán hallazgos, evidencias, severidad y recomendaciones (las vulnerabilidades críticas serán notificadas de forma inmediata).

7. INVESTIGACIÓN

- **Metodología elegida.** OWASP Web Security Testing Guide (WSTG). Marco técnico de pruebas web adecuado para la aplicación de Aurora Market; estructura casos para fingerprinting, configuración, identidad, autenticación, autorización, sesiones, validación de entradas y lógica de negocio. Será enfocada a caja gris.
- **Utilidad para Aurora Market.** Permite convertir flujos funcionales en casos de prueba trazables, comparar matrices de acceso entre cuentas y roles, validar hallazgos reproducibles y correlacionar vector, evidencia, impacto y remediación. El resultado será riesgo técnico verificado, en caso de existir.
- **Aplicación práctica.** Para este caso se priorizarán controles WSTG de enumeración, autenticación, autorización, gestión de sesión, entradas y lógica de negocio. Para investigar el reporte se ejecutarán pruebas diferenciales con cuentas y objetos de prueba, manipulando identificadores y contexto de sesión.
- **Resultado esperado.** Evidencias técnicas que servirán para atender posibles brechas de seguridad en la aplicación web (confirmando con un retest posterior la eficacia de las remediaciones) y, a su vez, pone foco en acciones y decisiones organizacionales prioritarias a fin de proteger la operación y los datos, y, por ende, fortalecer la confianza de los clientes de Aurora Market.